

Projeto de Bloco: Análise e Segurança de Agentes de IA

TP2 - EduBot Analytics

Alunas: Maitê Mota Belo de Souza Silva e Patricia Dias Rodrigues

Professor: Ricardo Pires Mesquita

Data: 30/09/2026

1. Objetivo

O TP2 aprofundou a análise do dataset e transformou a API inicial em uma aplicação com persistência, autorização por recurso, validação estrita e controles HTTP. A entrega também inclui testes automatizados e um scan passivo com OWASP ZAP.

2. Dados e EDA

O Bibtex tratado do TP1 foi mantido para preservar a continuidade da análise. Como resposta ao feedback do professor, também foi preparada uma amostra com 300 perguntas acadêmicas em português, obtidas do dataset `liteofspace/unb-chatbot-dpo`.

A fonte acadêmica não declara licença. Por esse motivo, o texto não foi copiado para o repositório. O script `eda/preparar_amostra_academica.py` baixa os dados para um cache local, enquanto o arquivo versionado contém apenas identificadores, hashes e rótulos de triagem.

Comparação de domínio

- Bibtex: 21.006 mensagens, média de 8,81 palavras e 30,17% com termos simples de e-commerce usados na comparação.
- Amostra acadêmica: 300 mensagens, média de 15,17 palavras e 52,33% com termos acadêmicos usados na comparação.

Essa diferença confirma a limitação apontada no TP1. O remapeamento de rótulos não torna o texto de e-commerce equivalente a uma mensagem universitária.

Visualizações

O notebook `eda/eda_edubot_tp2.ipynb` contém:

- heatmap de correlação de Spearman;
- scatter plot de caracteres por palavras, separado por categoria;
- scatter plot de comprimento por quantidade de marcas de ruído.

Teste da H1

A H1 afirma que pedidos ligados a justificativa ou acompanhamento de processo tendem a ser mais longos que pedidos diretos.

Foi usado Mann-Whitney bicaudal:

- pedidos diretos: 4.571 mensagens, média 8,39 e mediana 8 palavras;
- processo ou justificativa: 4.460 mensagens, média 9,24 e mediana 9 palavras;

- $U = 12.057.178$;
- $p\text{-valor} = 1,054e-51$;
- Cliff's delta = 0,183.

O resultado rejeita a igualdade entre as distribuições, mas o efeito é pequeno. O comprimento pode ajudar o futuro modelo, porém não deve ser usado sozinho.

Urgência

O `urgencia_proxy` do TP1 foi abandonado como alvo. A nova rubrica considera prazo e impacto acadêmico, não hostilidade. Os rótulos atuais são uma triagem e precisam de revisão humana antes do treino.

3. API

A API usa FastAPI, SQLite e SQLAlchemy. Não há SQL raw. Os schemas de entrada rejeitam campos extras com `extra="forbid"`.

O endpoint `/predict` cria uma `Solicitacao` ligada ao usuário por `owner_id`. A consulta por ID verifica o recurso e o usuário autenticado. Um ID inexistente ou pertencente a outra pessoa retorna 404.

4. Controles de segurança

- JWT com expiração de 30 minutos;
- senhas armazenadas com hash bcrypt;
- ownership em recursos por ID;
- HSTS;
- `X-Frame-Options: DENY`;
- `X-Content-Type-Options: nosniff`;
- `Content-Security-Policy` restrita;
- CORS com allowlist explícita;
- limite de 5 tentativas por minuto em `/auth/token`;
- middleware do SlowAPI para aplicar o rate limit.

O rate limit usa memória porque a entrega executa uma instância local. Em produção com mais de um processo, o armazenamento deve ser compartilhado em Redis.

5. Testes

A suíte da API possui quatro testes. Ela cobre:

1. acesso ao `/predict` sem token;
2. acesso a solicitação de outro usuário;
3. envio de campo extra;
4. fluxo válido de login, criação e retorno de solicitação.

Resultado:

4 passed

6. OWASP ZAP

O scan foi executado pela Patricia com OWASP ZAP 2.17.0, em modo passivo e com tráfego autenticado.

O primeiro scan encontrou dois alertas Medium:

- diretivas CSP sem fallback explícito;
- ausência de CSP em `/openapi.json`.

As diretivas `frame-ancestors`, `base-uri` e `form-action` foram adicionadas, e `/openapi.json` passou a receber o header CSP. Um segundo scan confirmou que os dois findings Medium desapareceram.

O alerta informativo de HSTS sobre HTTP local foi aceito porque o header só produz efeito em HTTPS. Os relatórios estão em `security/zap-report-inicial.html` e `security/zap-report-verificacao.html`.

7. Limitações e próximos passos

- O Bitext continua fora do domínio acadêmico.
- A amostra acadêmica não representa logs reais e ainda precisa de revisão humana.
- SQLite e rate limit em memória são adequados apenas à execução local.
- O scan ZAP foi passivo e não substitui pentest.
- O próximo passo é finalizar os rótulos, separar os dados por fonte e criar um baseline de classificação.

8. Uso de IA

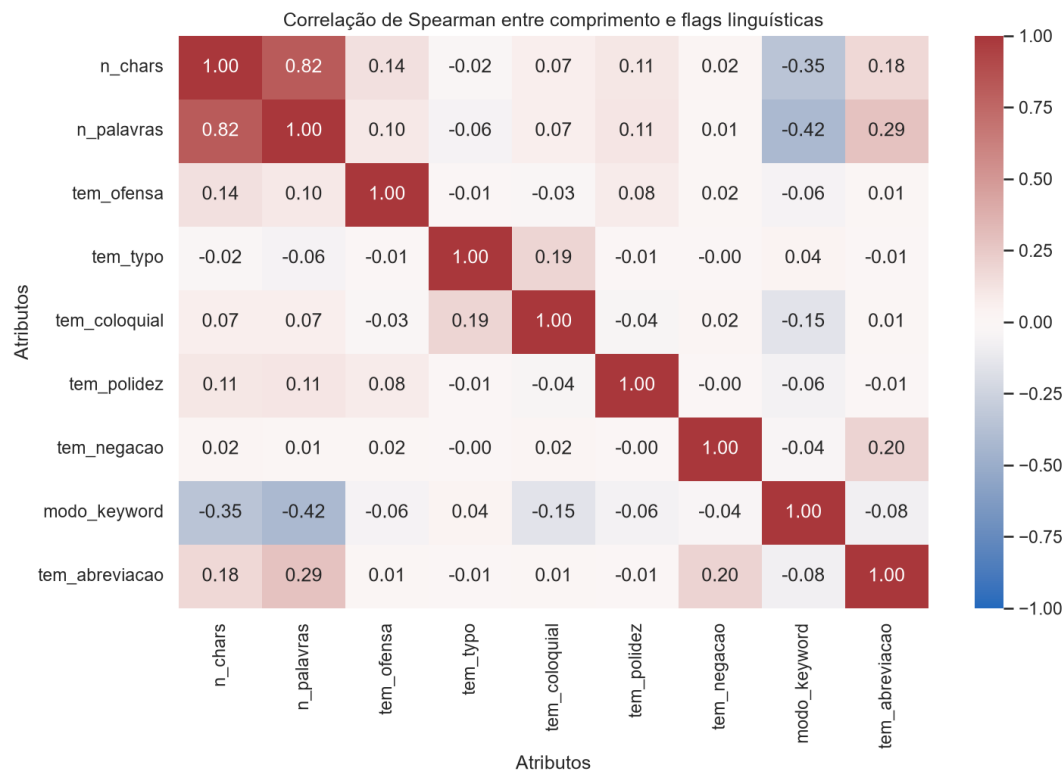
O Cursor foi usado na parte de dados para pesquisar fontes, escrever scripts, estruturar o notebook e revisar a documentação. A Patricia registrou o uso do Claude como apoio na implementação e revisão da API. As estatísticas, testes e relatórios foram produzidos pela execução das ferramentas indicadas. As autoras são responsáveis por conferir fontes, rótulos, decisões técnicas e interpretações.

9. Arquivos da entrega

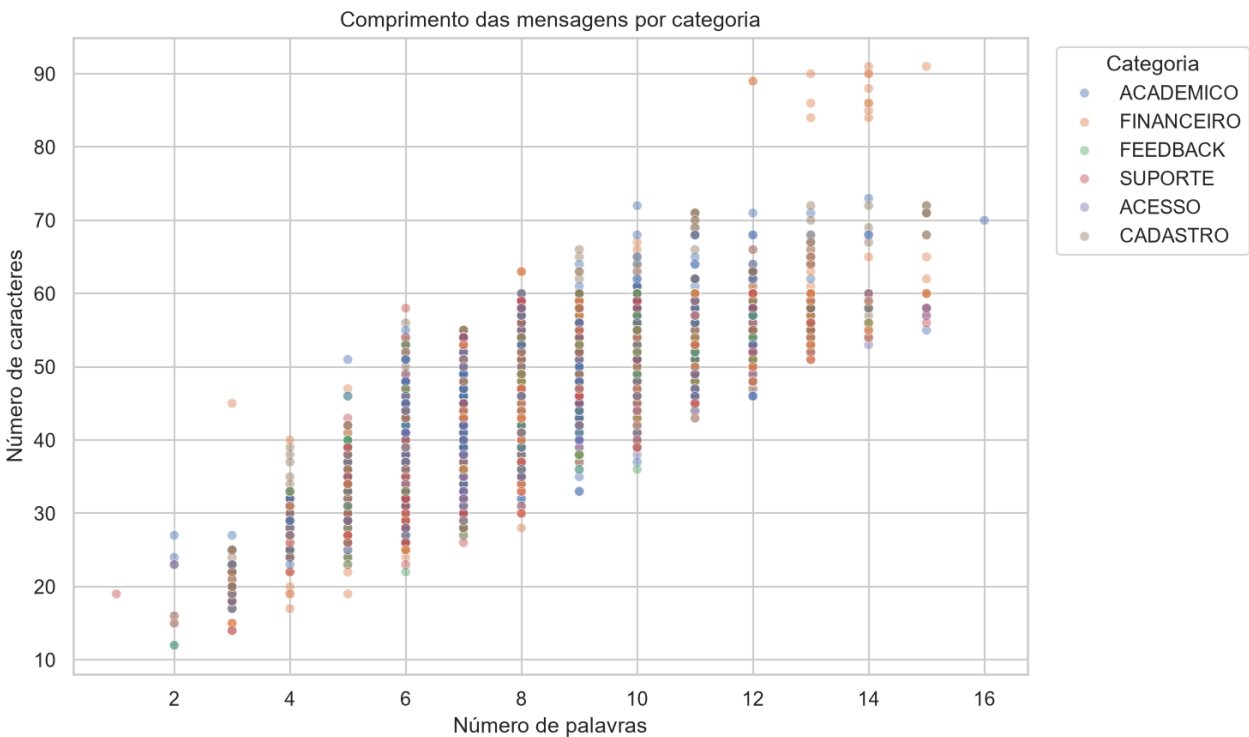
- `eda/eda_edubot_tp2.ipynb`
- `eda/relatorio_eda_tp2.md`
- `api/tests/`
- `security/decisoes-tecnicas.md`
- `security/zap-findings.md`
- `security/zap-report-inicial.html`
- `security/zap-report-verificacao.html`

Figuras da EDA

Heatmap de correlação



Comprimento por categoria



Comprimento e ruído

